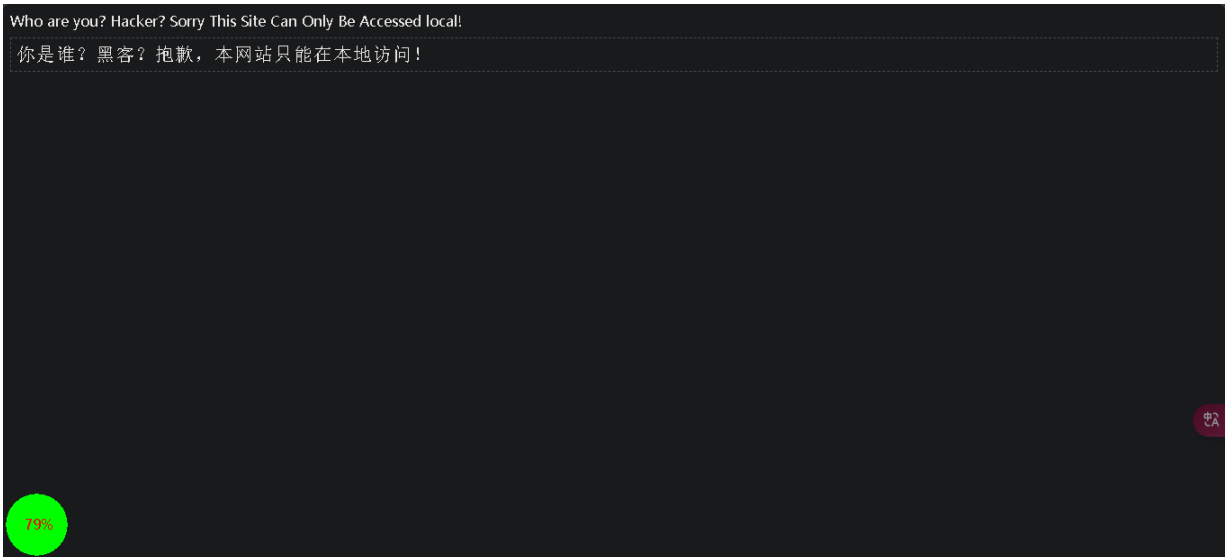


day04 Me and My Girlfriend

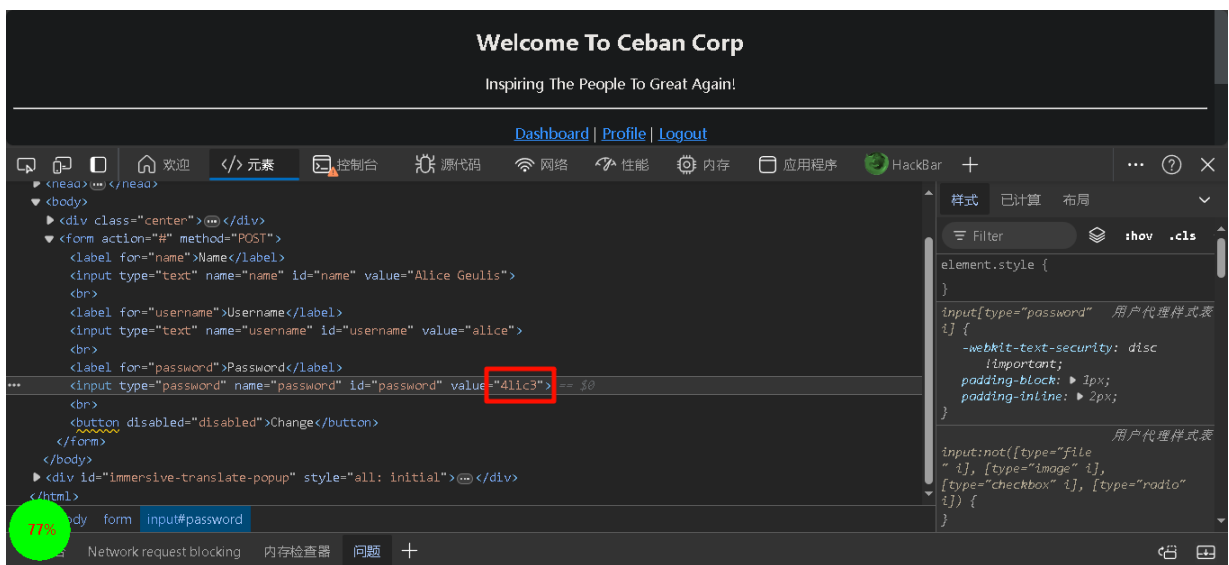
这个靶机涉及了一点剧情

这个VM告诉我们，有一对恋人，即爱丽丝和鲍勃，这对夫妇原本非常浪漫，但由于爱丽丝在一家私人公司“Ceban Corp”工作，爱丽丝对鲍勃的态度发生了一些变化，就像“隐藏”的东西一样，鲍勃请求你的帮助，以获得爱丽丝隐藏的东西并获得对公司的完全访问权限！

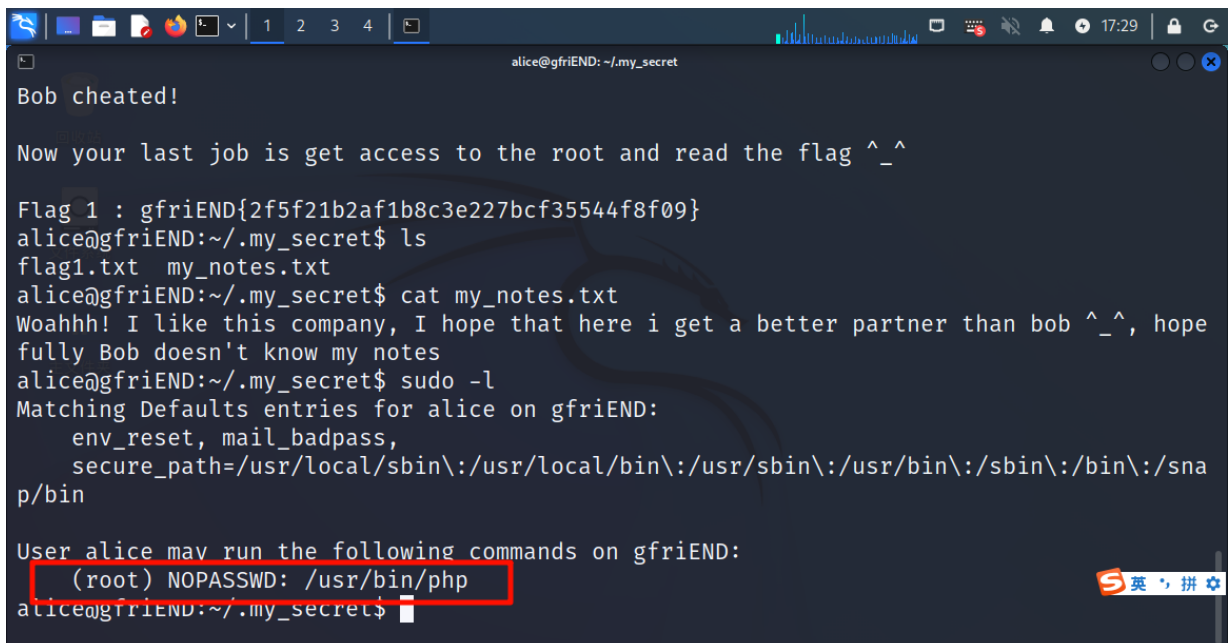
1. 主机发现 `nmap -sn 192.168.111.0/24` ,目标IP为192.168.111.134
2. 扫描端口 `nmap -p- 192.168.111.134` 有80和22端口



3. 只能本地访问那么用XFF绕过使用BP在每个请求头中添加 `x-forwarded-for:localhost` 来XFF绕过也可以在BP中添加规则这里不再概述
4. 好的现在可以访问了现在点击Register注册用户
5. 点击Profile 获取用户信息，可以看到地址栏有id
6. 那么修改地址的id来查找爱丽丝的账号密码当user_id=5时出现了Alice的账号，现在来用浏览器自带的检查来看前端存储的密码



7. 使用ssh连接, `ssh alice@192.168.111.134` 密码4lic3,使用 `ls -liah` 查找隐藏文件,打开.my_secret, 里面有个flag1.txt这个就是了
8. flag1 `gfriEND{2f5f21b2af1b8c3e227bcf35544f8f09}` 上面有段文字吃个瓜!
like this company, I hope that here i get a better partner than bob ^_^,
hopefully Bob doesn't know my notes 意思是 我喜欢这家公司, 我希望在这里
我能找到一个比鲍勃^_^更好的合作伙伴, 希望鲍勃不知道我的笔记
9. 好的吃瓜完毕现在该提权了看一下有什么权限



/usr/bin/php有root权限, 启动一下shell `sudo /usr/bin/php -r "system('/bin/bash');"` 现在有root权限了

10. flag2.txt在root目录下flag2 `gfriEND{56fbee560930e77ff984b644fde66e7}`

总结

1. 主机发现, XFF绕过本地识别

2. 注册用户，撞库获取alice账号密码
3. 连接获取flag1
4. 发现/usr/bin/php有root权限使用他启动shell
5. 获取flag2
6. 这个时候Bob该去哪哭呢 doge